

Risk

Jorge Blasco Alis

Adapted for Seguridad de la Información (UPM-ETSISI)



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON

What is Risk?



Risk

Probability of something harmful to happen

Risk

Effect of uncertainty on objectives

ISO/IEC 31000

Risk

Potential that a given threat will exploit vulnerabilities of an asset or group of assets and thereby cause harm to the organization

ISO/IEC 27005

What are the components of risk?



- Independently of the definition 3 components are needed for risk to exist
- Causative Agent
 - Someone or something
- Weakness – Vulnerability
 - That is used by the causative agent
- Harm – Impact
 - Damage done to the assets

Threat

The possible danger that comes from the exploitation of a vulnerability of weakness



- 2 types
 - Accidental – Hazard
 - Malicious – Threat
 - Motivation
 - Capabilities

Examples?

Weakness I

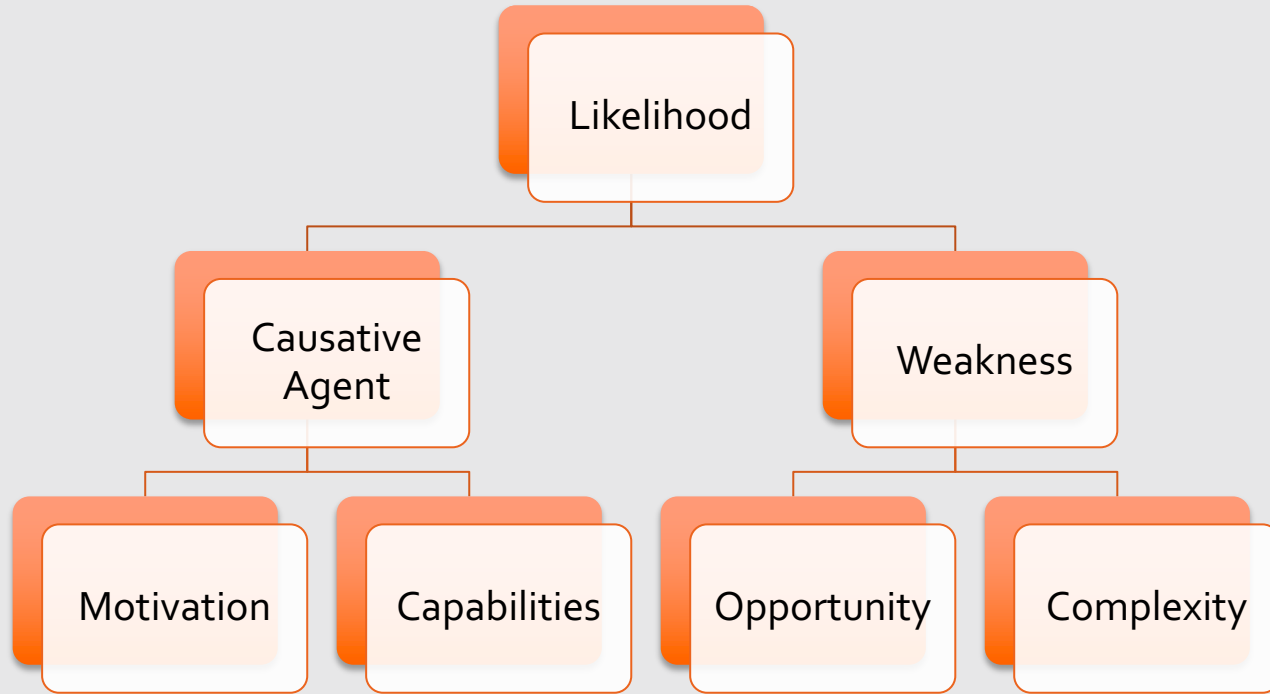


- Vulnerabilities of an organisation
 - Physical
 - Access to buildings
 - Procedural
 - Lack of invoice checks
 - Personnel
 - Not checking for criminal records
 - Logical
 - Software bugs



- Properties
 - Opportunity
 - Complexity
- Particular definition of these depend on its type
- For software vulnerabilities
 - Opportunity: Access Vector
 - (Network, Physical access, etc.)
 - Complexity
 - How complex is to develop an exploit?

Likelihood of the Threat



Examples?

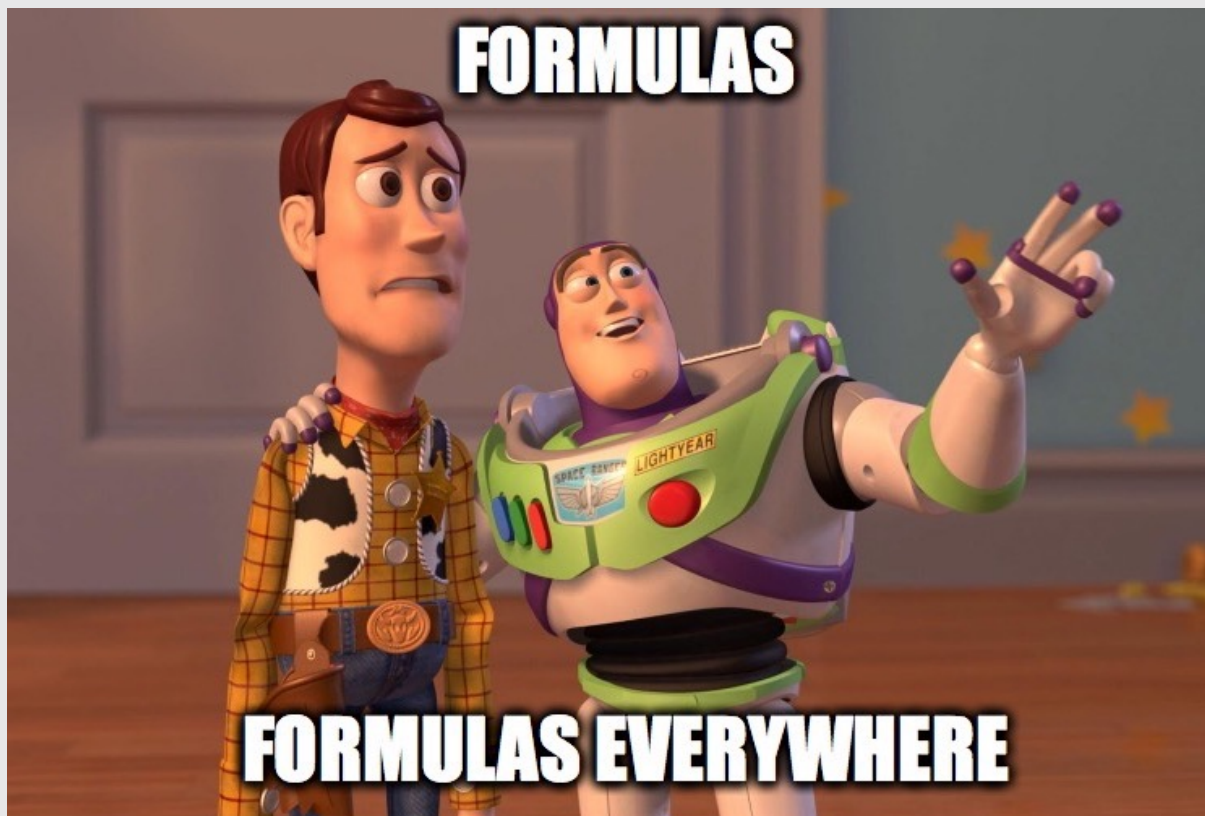


- The harm caused if the vulnerability is exploited
- For information systems in terms of the loss of
 - Confidentiality
 - Integrity
 - Availability
- Impact depends on
 - The asset
 - The time when the vulnerability is exploited
 - The nature of the threat

Examples



- Loss of confidentiality
 - Marketing plans
 - Customer database
- Loss of integrity
 - Ransomware
 - Installation of phishing website
- Loss of availability
 - E-commerce
 - Payment gateway



$$Risk = Agent \cdot Vulnerability \cdot Impact$$

1

2

3

$$1 \ Agent = Motivation \cdot Capabilities$$

$$2 \ Vulnerability = Opportunity \cdot Complexity$$

$$3 \ Impact = Confidentiality \cdot Integrity \cdot Availability$$



Risk =

*Motivation · Capabilities · Opportunity
· Complexity · Confidentiality · Integrity
· Availability*

Likelihood = Agent · Vulnerability

Risk = Likelihood · Impact

Risk Management



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON

What is Risk Management?



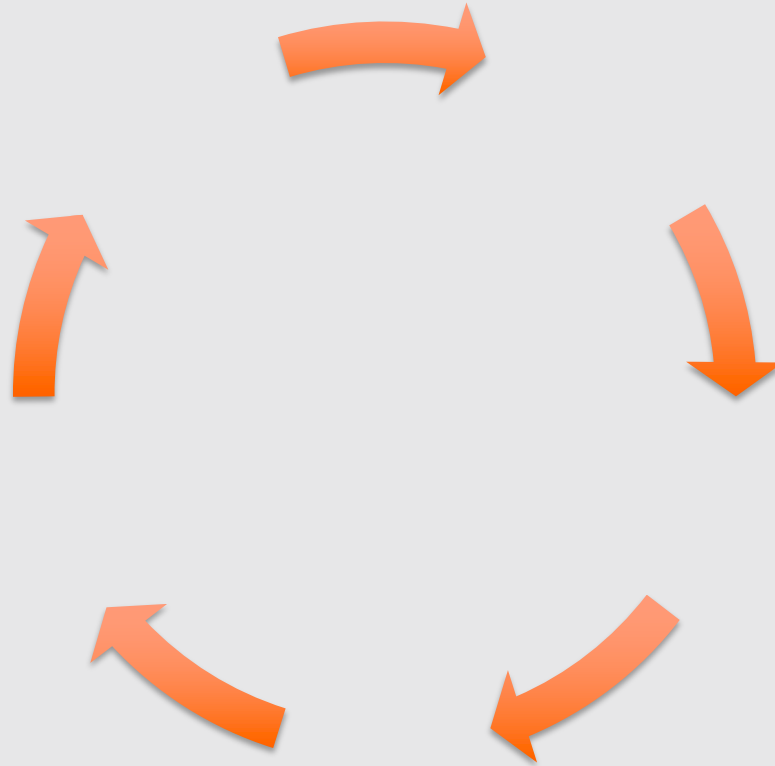
- Risk is not just an information security issue

Examples?



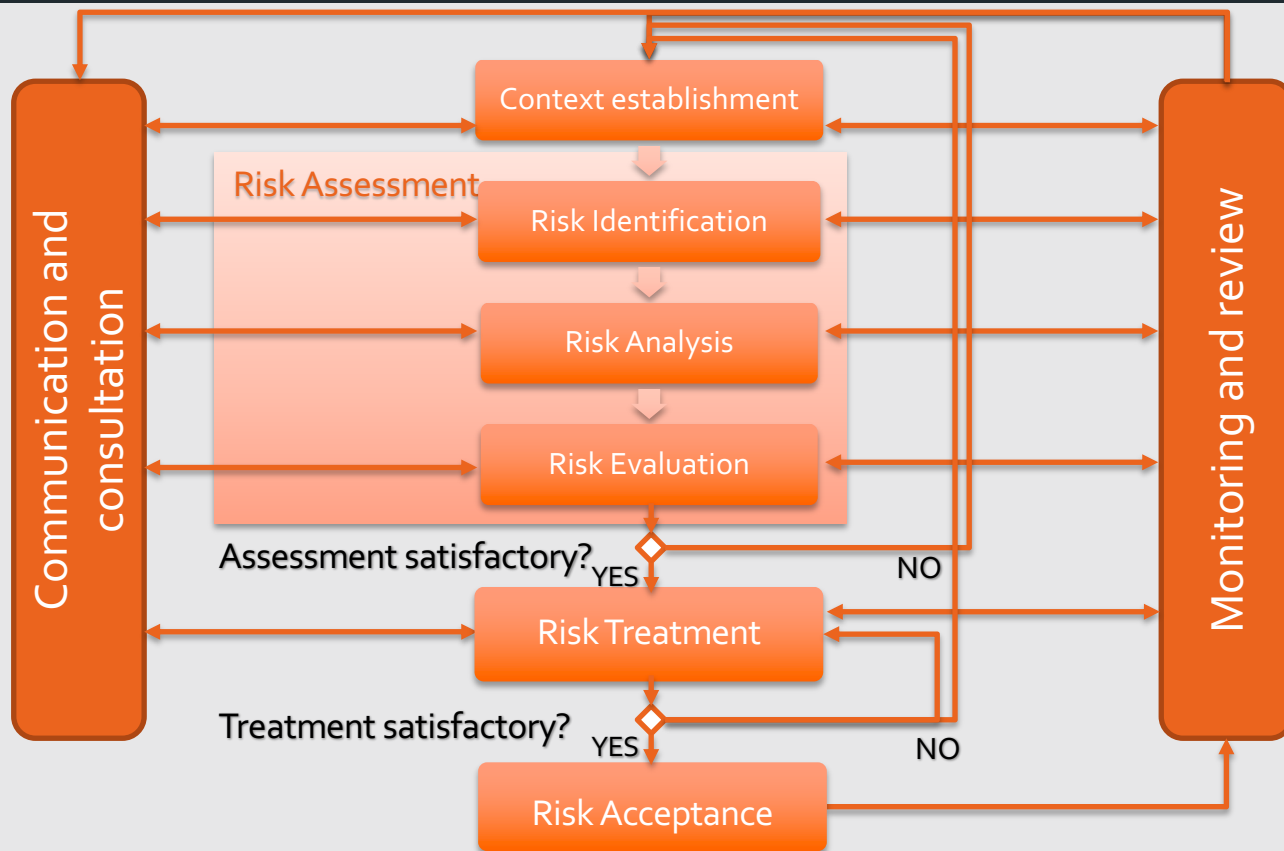
- Deals with the risks that originate from the use of information systems
- Many different approaches
 - ISO/IEC: 27001 and 27005
 - COBIT
- In this course, we focus on the ISO 27005 approach
- One element common to all approaches

Examples?



Risk Management is a continuous process

Overview



Why iterative?



- Risks change with time
 - New vulnerabilities
 - New assets
 - New attackers
- Can increase details/depth at each iteration
- Balance minimising effort in identifying controls while ensuring high risks are properly assessed

Context Establishment



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON



- Define internal and external context
 1. Set the basic criteria
 - How risks will be evaluated
 2. Define the scope and boundaries
 - What sorts of risks and assets will be looked at
 3. Establish the process organisation
 - How the individuals doing the work will be organised



RISK CRITERIA FOR IMPACT

THREATS	Factor	Score	Effect on Level of Service	Effect on Quality of service	Embarrassment/reputation	Personal Safety	Personal privacy infringement	Failure to provide statutory duties/meet legal obligations	Financial loss	Effect on Project Objectives/ Schedule Deadlines
	Extreme	4	Massive loss of service, including several important areas of service and /or protracted period; service disruption 5+ days	Quality of service deteriorates by over 80% from accepted (ideally defined by PI's) operating parameters.	Adverse and persistent national media coverage; adverse central government response, involving (threat of) removal of delegated powers; officer(s) and/or members forced to resign	Death of an individual or several people	All personal details compromised/ revealed	Litigation/ claims/fines from departmental £250k + corporate £500k +	Costing over £500,000 Up to 75% of budget	Complete failure of project/ extreme delay – 3 months or more
	Major	3	Complete loss of an important service area for a short period; major effect to services in one or more areas for a period of weeks; service disruption 3-5 days	Quality of service deteriorates by between 25% to 60% from accepted (ideally defined by PI's) operating parameters.	Adverse publicity in professional/municipal press, affecting perception/standing in professional/local government community; adverse local publicity of a major and persistent nature; statutory prosecution of a serious nature.	Major injury to an individual or several people	Many individual personal details compromised/ revealed	Litigation/ claims/fines from departmental £50k to £125k corporate £100k to £250k	Costing between £50,000 and £500,000 Up to 50% of budget	Significant impact on project or most of expected benefits fail/ major delay – 2-3 months
	Moderate	2	Moderate effect to an important service area for a short period; adverse effect to services in one or more areas for a period of weeks; service disruption 2-3 days	Quality of service deteriorates by between 10% to 25% from accepted (ideally defined by PI's) operating parameters.	Adverse local publicity /local public opinion aware; statutory prosecution of a non-serious nature	Severe injury to an individual or several people	Some individual personal details compromised/ revealed	Litigation/ claims/fines from departmental £25k to £50k Corporate £50k to £100k	Costing between £5,000 and £50,000 Up to 25% of budget	Adverse effect on project/ significant slippage – 2 weeks–2 months
	Minor	1	Brief disruption of important service area; significant effect to non-crucial service area; service disruption 1 day	Quality of service deteriorates up to 10% away from accepted (ideally defined by PI's) operating parameters.	Contained within section/unit or directorate; complaint from individual/small group, of arguable merit	Low degree injury or discomfort to an individual or several people	Isolated individual personal detail compromised/ revealed	Litigation/ claims/fines from departmental £12k to £25k corporate £25k to £50k	Costing less than £5,000 Up to 10% of budget	Minimal impact to project/ slight delay less than 2 weeks

**RISK CRITERIA FOR LIKELIHOOD**

FACTOR	SCORE	THREATS - DESCRIPTION	INDICATORS
Very likely	4	More than 75% chance of occurrence.	Regular occurrence. Circumstances frequently encountered - daily/weekly/monthly.
Likely	3	40% - 75% chance of occurrence.	Likely to happen at some point within the next 1-2 years. Circumstances occasionally encountered (few times a year).
Unlikely	2	10% - 40% chance of occurrence.	Only likely to happen 3 or more years.
Very unlikely	1	Less than 10% chance of occurrence.	Has happened rarely/never before.

Royal Borough Windsor and Maidenhead approach to management of Risk



- Define level of risk the organisation is willing to accept
- Different ways of expressing this level
 - Multiple thresholds for different assets/departments/risk classes
 - Risk from law or regulations is generally not accepted
 - Senior managers may accept additional risk under defined circumstances
 - Ratio of estimated profit to the estimated risk
- Accept risk with commitment of reducing it to an acceptable level in a defined time-frame

Risk Appetite Statements



low appetite	low/medium appetite	medium appetite	medium/high appetite	high appetite
Avoidance of risk and uncertainty is a key organisational objective.	Preference is for ultra safe business delivery options that have a low level of inherent risk and only have a potential for limited reward.	Preference is for safe delivery options that have a low degree of inherent risk and likely to only have limited potential for reward in most circumstances.	Willing to consider all potential delivery options and choose the one most likely to result in successful delivery while also providing an acceptable level of reward.	Eager to be innovative and to choose options offering potentially higher business rewards despite greater inherent risks.

Royal Borough Windsor and Maidenhead approach to management of Risk

Risk Acceptance Criteria example



Risk assessment heat map

I M P A C T	4	4	8	12	16
	3	3	6	9	12
	2	2	4	6	8
	1	1	2	3	4
		1	2	3	4
		LIKELIHOOD			

Royal Borough Windsor and Maidenhead approach to management of Risk

6 RISK MANAGEMENT ROLES AND RESPONSIBILITIES

Managing director

The MD takes overall responsibility for RBWM risk management performance and in particular ensures that:

- decision-making is in line with RBWM policy and procedures for management of risk;
- adequate resources are made available for the management of risk;
- there is an understanding of the risks facing RBWM.

- Review an annual report on corporate governance (annual governance statement).

Head of finance

- Ensure that a risk management policy and strategy is developed and reviewed annually to reflect the changing nature of the council.
- Champion the process of risk management as good management practice and a valuable management tool.

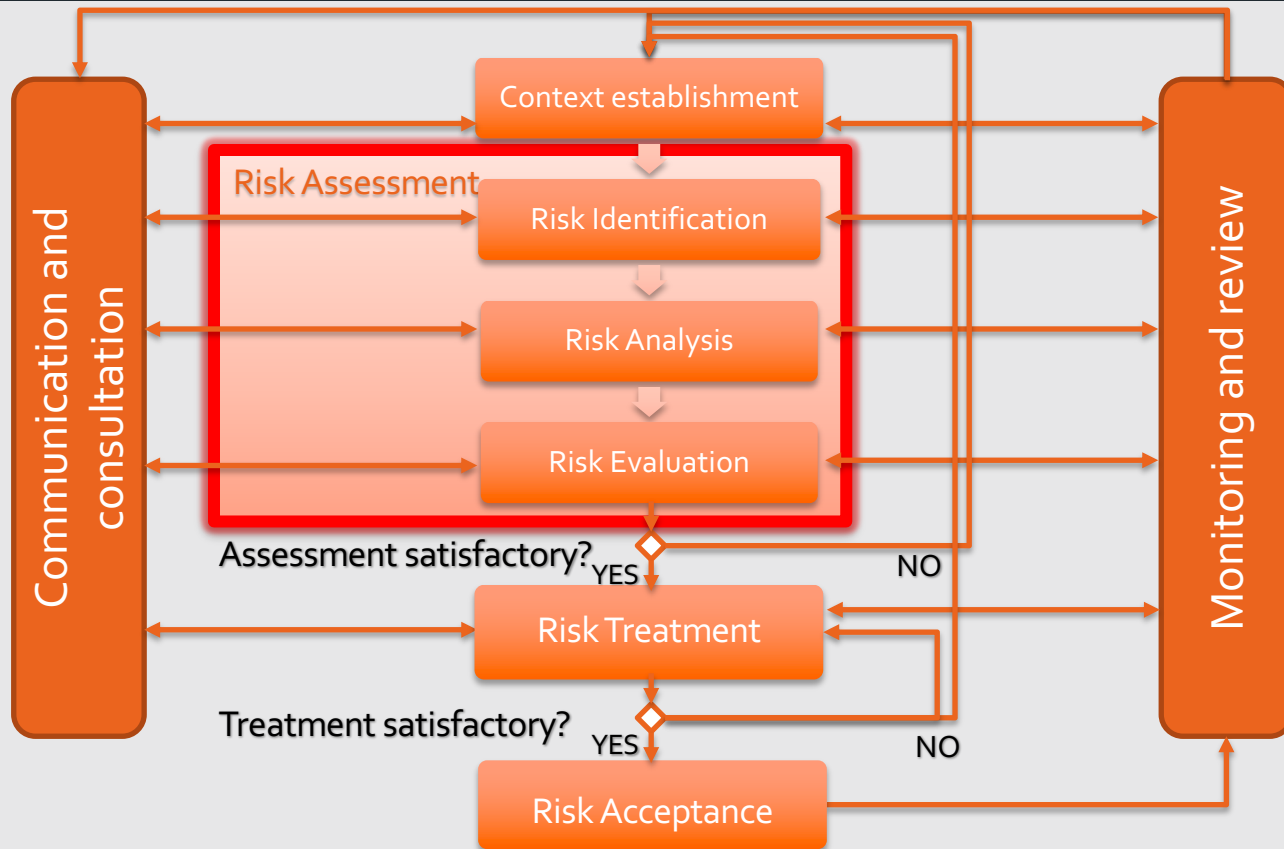
Royal Borough Windsor and Maidenhead approach to management of Risk

Risk Assessment



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON

Overview

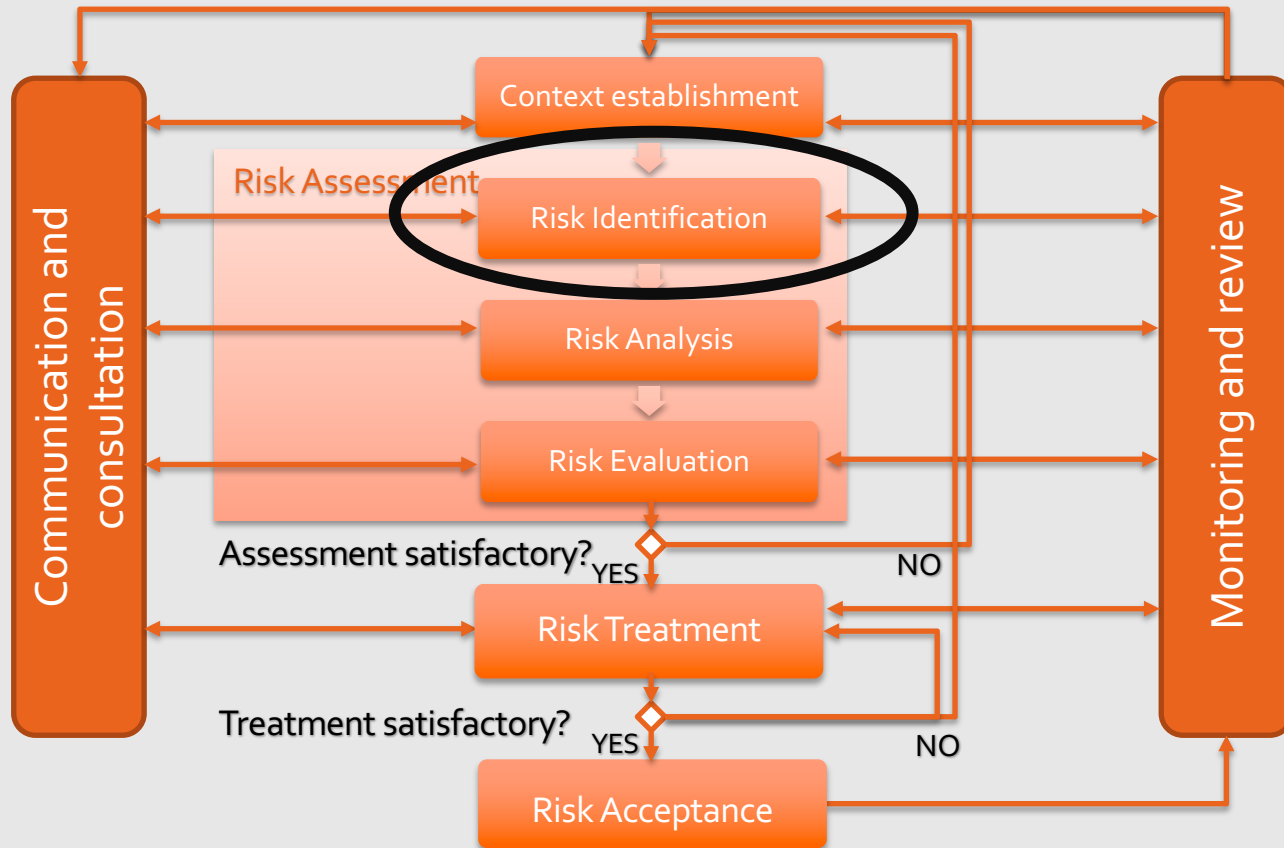


Risk Identification



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON

Overview





- Determine what could happen to cause a potential loss
 - how, where and why the loss might happen
- We must include all risks, whether or not their source is under the control of the organisation
- Several approaches
 1. Asset
 2. Threats
 3. Vulnerabilities and causative agents



Assets				



Assets	Threats			



Assets	Threats	Controls		



Assets	Threats	Controls	Vulnerabilities	



Assets	Threats	Controls	Vulnerabilities	Consequences



- Identify
 - Assets
 - Threats
 - Controls
 - Vulnerabilities
 - Consequences

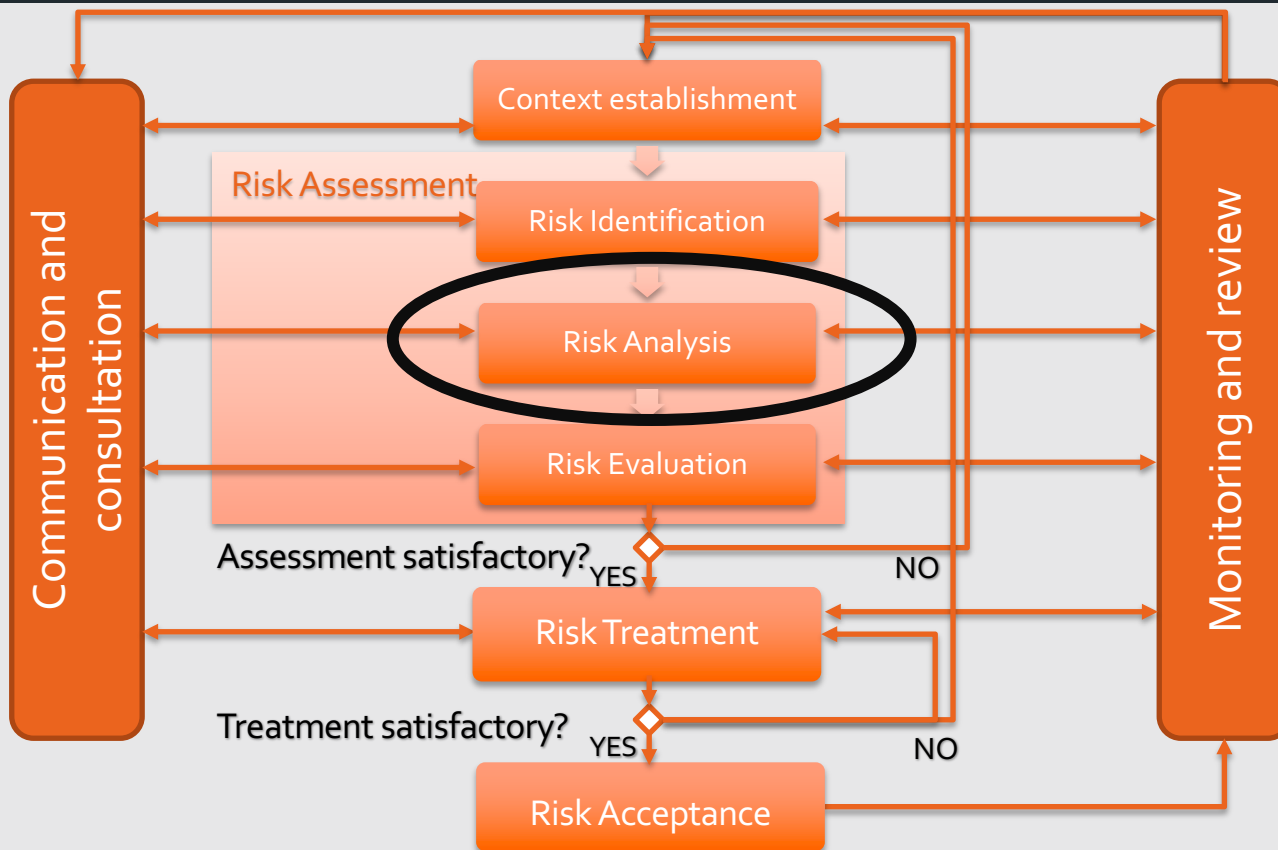
Now what?

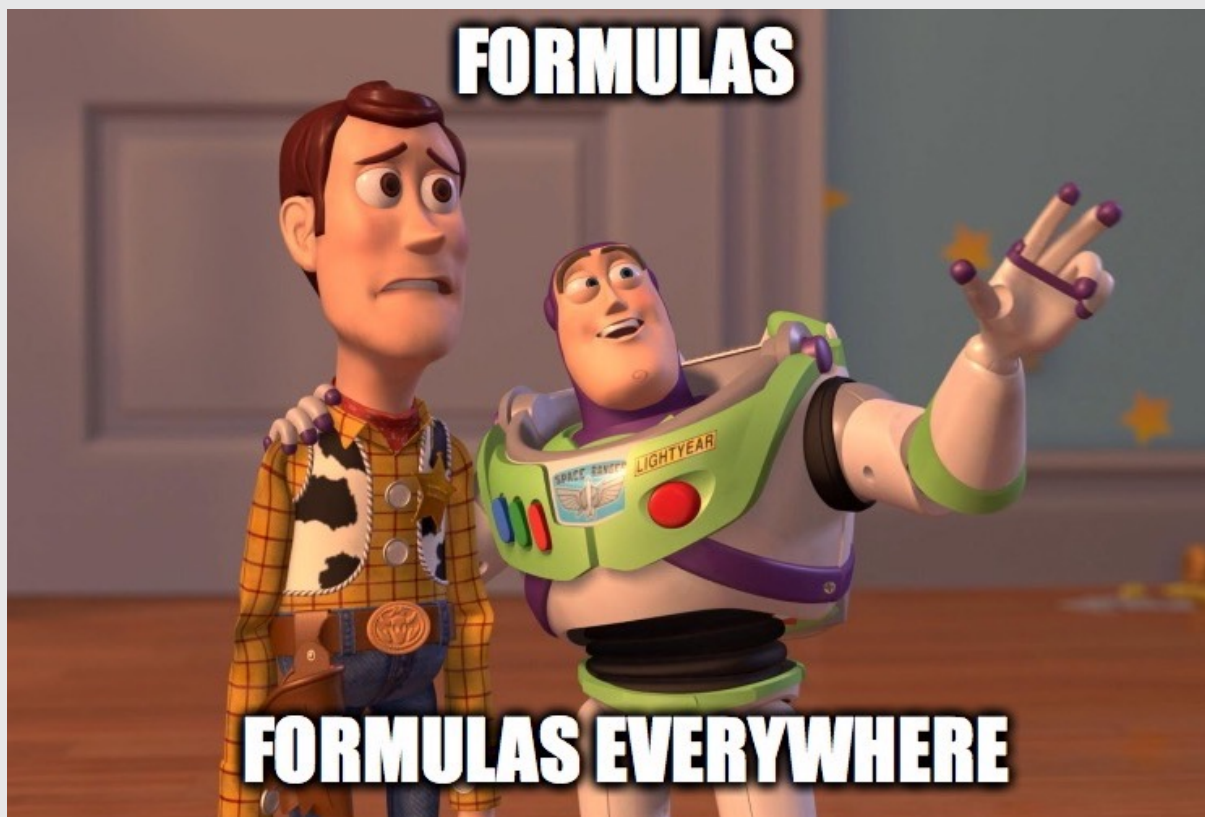
Risk Analysis



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON

Overview





Risk =

*Motivation · Capabilities · Opportunity
· Complexity · Confidentiality · Integrity
· Availability*

Likelihood = Agent · Vulnerability

Risk = Likelihood · Impact



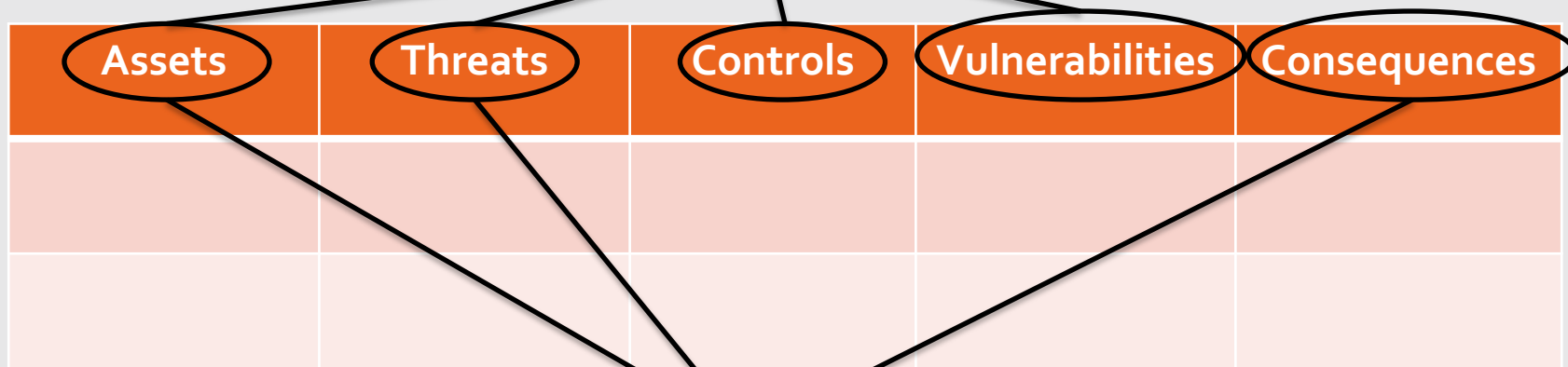
- We measure the business impact
- For each asset we measure how loss of each element of CIA affects the business
 - Financial: asset replacement, fine, etc.
 - Legal: licence, legal responsibilities, etc.
- Can be described qualitative or quantitative
- Quantitative description will probably provide more useful information



- Likelihood must be measure for each scenario and impact
- We can take into account current controls
- For deliberate threats
 - Motivation, capabilities and resources available to possible attackers, as well as attractiveness and vulnerability of assets for a possible attacker
- For accidental ones
 - Geographical factors e.g. proximity to chemical or petroleum plants, possibility of extreme weather conditions, and factors influencing errors and equipment malfunction



Likelihood



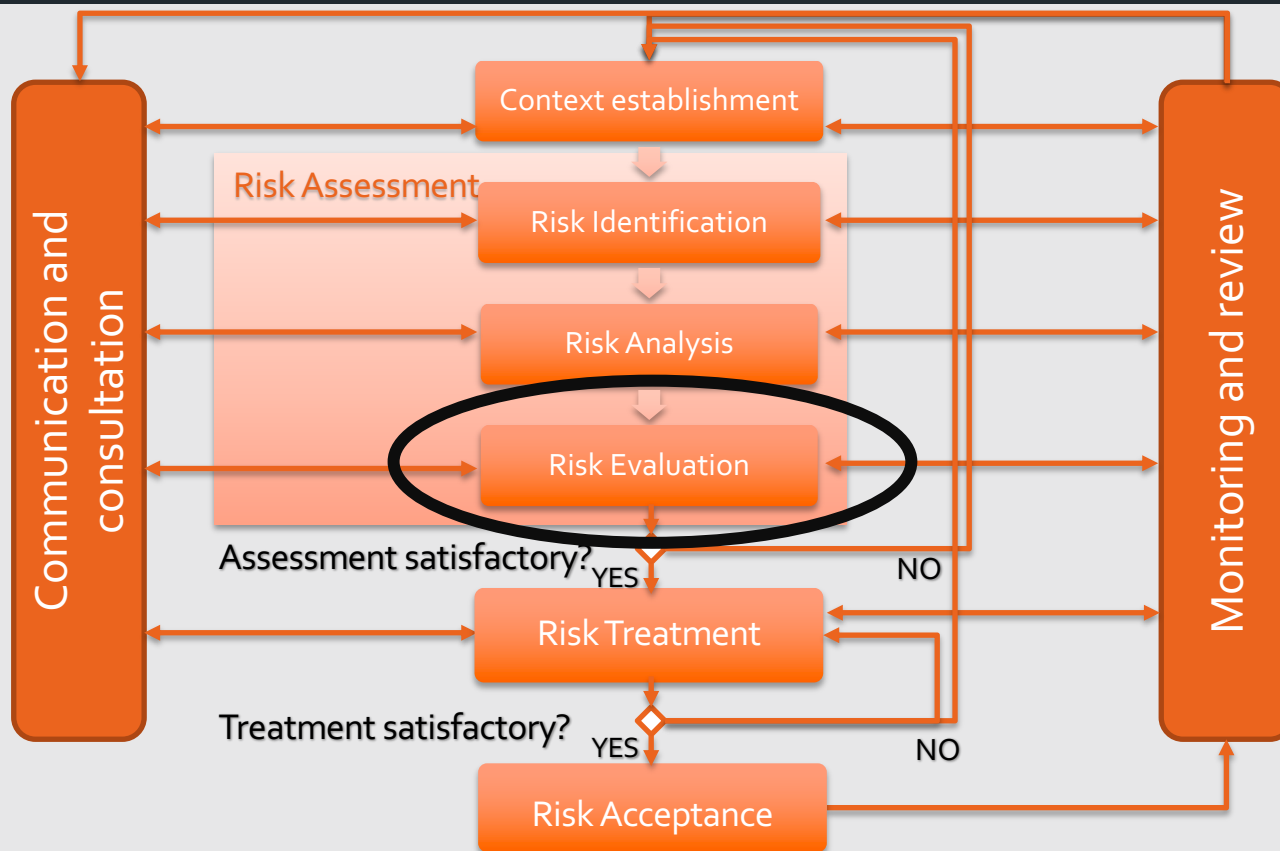
Impact

Risk Evaluation



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON

Overview



- Quantitative
 - Risk = Impact x Likelihood
- Qualitative

Colours?

	Likelihood					
		Rare	Unlikely	Possible	Likely	Certain
Impact	Catastrophic	4	5	6	7	8
	Major	3	4	5	6	7
	Moderate	2	3	4	5	6
	Minor	1	3	3	4	5
	Negligible	0	1	2	3	3



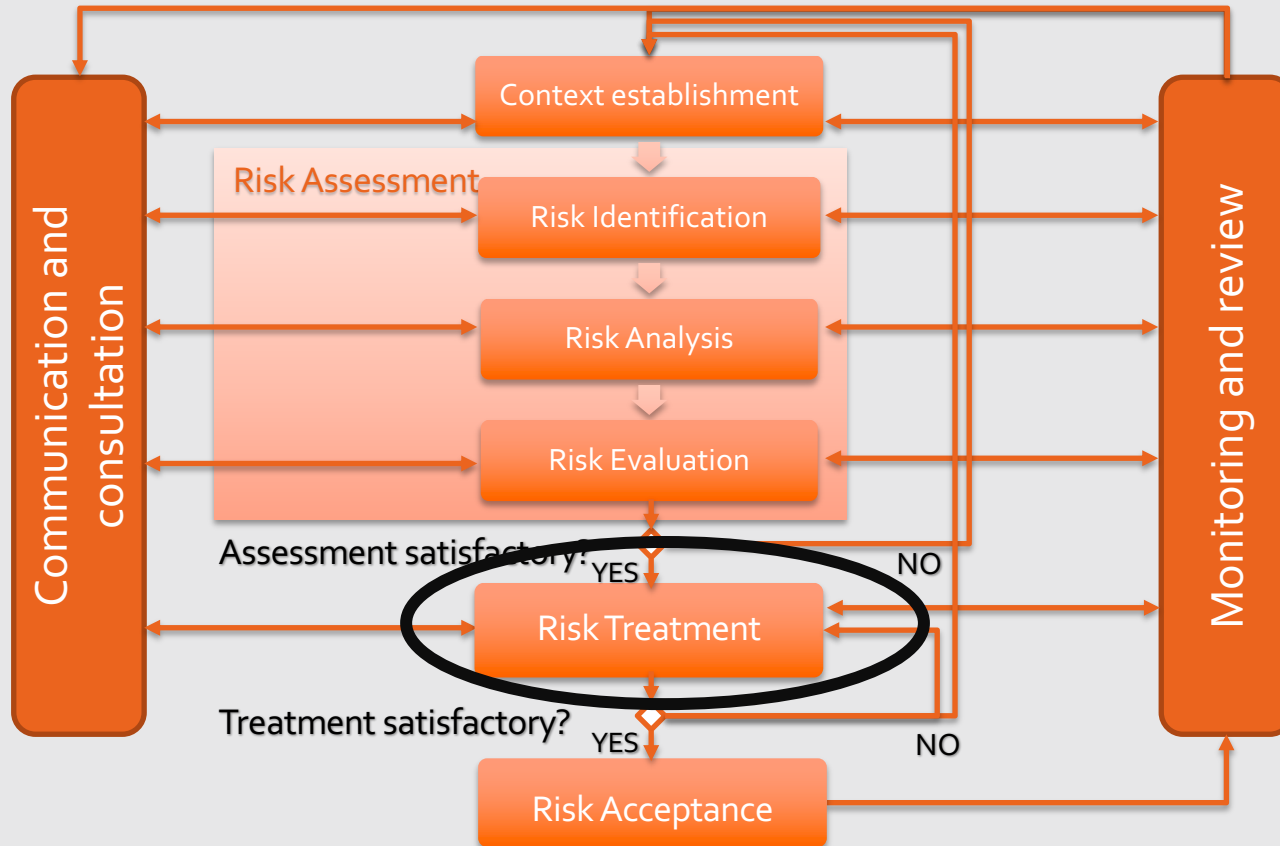
Assets	Threats	Likelihood	Impact	Risk

Risk Treatment



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON

Overview



Risk treatment options



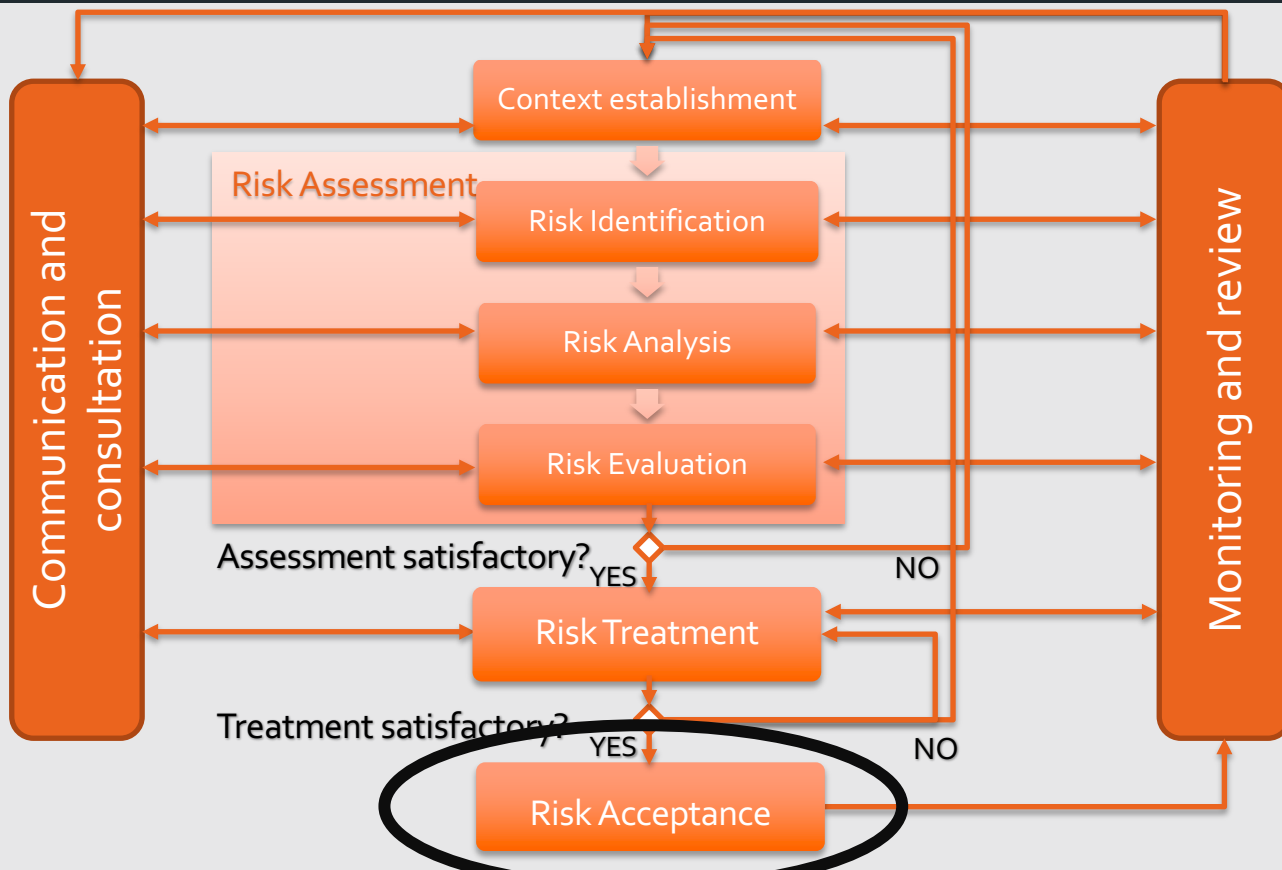
- 4 options
 - Modify (hopefully reduce)
 - Avoid
 - Transfer
 - Accept
- Risk treatment options should be selected based on
 - Risk assessment itself
 - Expected cost for implementing options
 - Expected benefits from these options

Risk Acceptance



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON

Overview





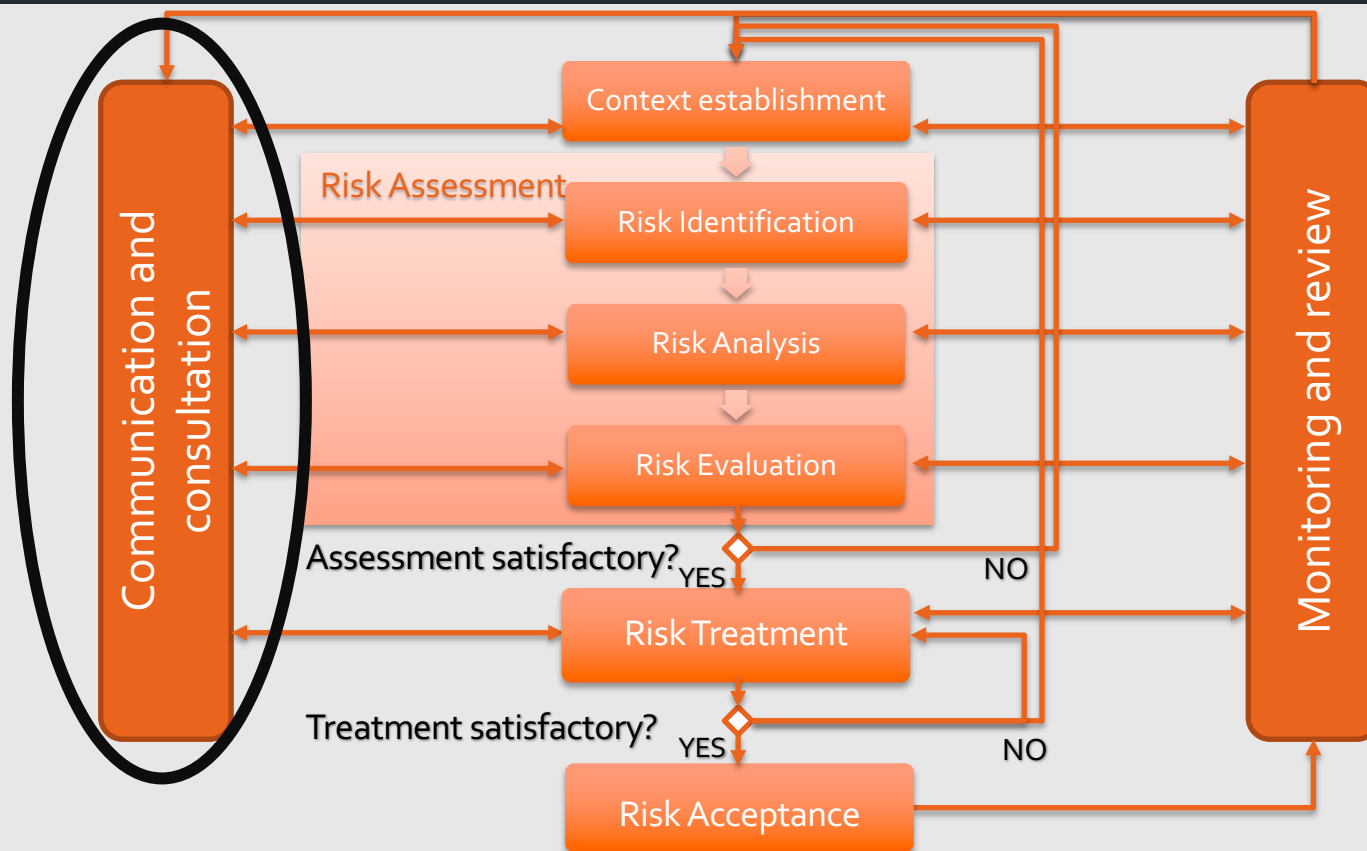
- Risk treatment may not immediately lead to an acceptable level of residual risk
- After treatment we verify if we have arrived to an acceptable risk level
 - If not, we revise the risk treatment
 - In some cases we may accept the risk because the potential benefits
- Risk acceptance activity must ensure residual risks are explicitly accepted by managers

Risk Communication and Consultation



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON

Overview





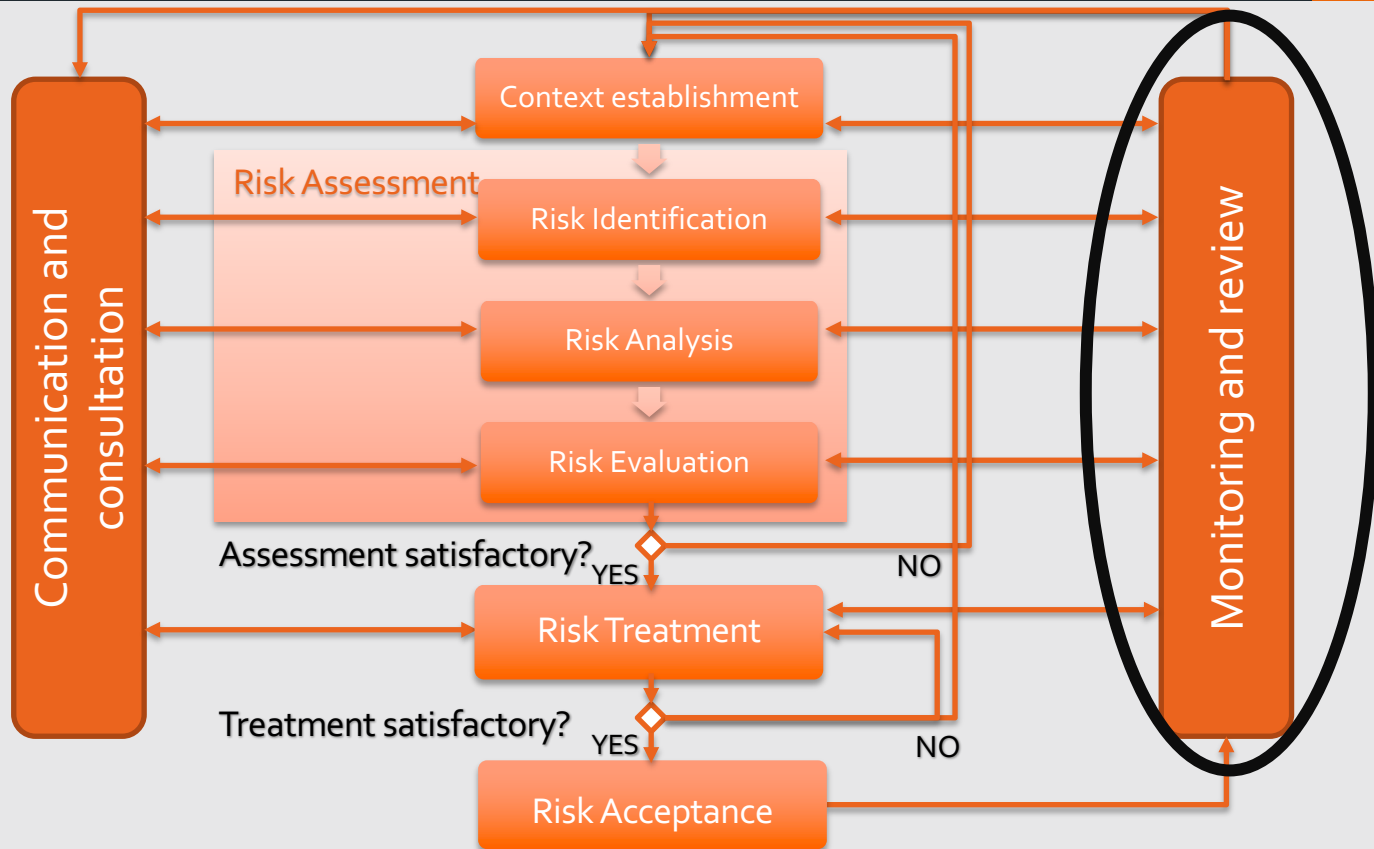
- Risks and their treatment must be communicated to managers and operational staff
- Even before risk treatment, information about identified risks can be very valuable to manage incidents, and may reduce damage
- Detailed results of risk management process should be documented

Risk Monitoring and Review



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON

Overview



Risk monitoring and review



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON

- Risks changes
 - Value of assets
 - Impacts
 - Threats
 - Vulnerabilities
 - Likelihood
- We need to monitor that treatment works!
- Risk management is a continuous process

Examples



- New assets
- Modification of asset values
- New threats outside and inside the organisation
- New or increased vulnerabilities
- Increased impact or consequences of assessed threats, vulnerabilities
- Information security incidents